

[► RAPPORT TECHNIQUE · EVE-NG LAB](#)

Mise en place d'une chaîne de sécurité multicouche
avec Palo Alto, F5 BIG-IP, WAF Nginx et OWASP Juice Shop

EVE-NG

Palo Alto

F5 BIG-IP

WAF / ModSecurity

Kali Linux

Juice Shop



Cybersécurité

· Défense en
profondeur

Réseau

· Architecture
multicouche

Type

· Rapport
technique

Table des Matières

- 01 Introduction & Contexte
- 02 Topologie & Plan d'adressage
- 03 Configuration des postes Linux
- 04 Configuration des Switches
- 05 Configuration du Pare-feu Palo Alto
- 06 Configuration du WAF Linux (Nginx + ModSecurity)
- 07 Configuration du F5 BIG-IP
- 08 Applications et Services Déployés
- 09 Tests & Validation Globale
- 10 Conclusion & Améliorations
- A Annexe – Commandes de vérification

01 Introduction & Contexte

1.1 Contexte du projet

Ce projet a consisté à construire, dans EVE-NG, une **architecture réseau de sécurité multicouche** destinée à protéger une application web exposée à des tests d'attaque. L'objectif n'était pas uniquement de faire communiquer des machines entre elles, mais de mettre en place une chaîne de sécurité complète selon le principe de **défense en profondeur**.

1.2 Objectifs techniques

- Comprendre et maîtriser l'environnement EVE-NG
- Concevoir une topologie réseau cohérente à plusieurs segments
- Configurer un pare-feu Palo Alto avec zones et règles de sécurité
- Intégrer un F5 BIG-IP comme équipement de transit réseau
- Déployer un WAF Linux (Nginx + ModSecurity) en reverse proxy
- Déployer OWASP Juice Shop et tester des vecteurs d'attaque
- Identifier les anomalies de routage et les corriger

1.3 Environnement de simulation

L'ensemble du projet a été réalisé sous **EVE-NG**, plateforme de simulation réseau virtualisée permettant de créer des nœuds virtuels, d'interconnecter différents équipements de sécurité et de simuler des segments réseau distincts.

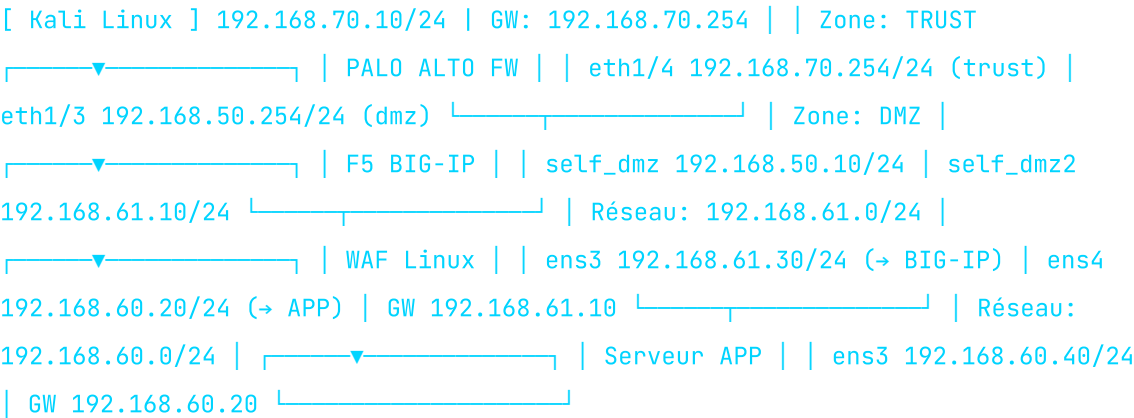
1.4 Équipements utilisés

ÉQUIPEMENT / SYSTÈME	RÔLE DANS LE PROJET
EVE-NG	Plateforme de simulation réseau
Kali Linux	Poste client / machine d'attaque
Palo Alto Firewall	Pare-feu inter-zones (trust / dmz)
F5 BIG-IP	Équipement intermédiaire – self IPs, routes, ip-forward
WAF Linux	Reverse proxy Nginx + ModSecurity

ÉQUIPEMENT / SYSTÈME	RÔLE DANS LE PROJET
Serveur Application	Hébergement de l'application web
OWASP Juice Shop	Application web vulnérable de test

02 Topologie & Plan d'adressage

2.1 Architecture logique finale



2.2 Justification de la segmentation



Problème identifié – Deux interfaces dans le même réseau

Au départ, les deux interfaces du WAF se trouvaient dans le même sous-réseau. Cela a provoqué des conflits ARP, des réponses ICMP incohérentes et des routes par défaut contradictoires. La solution définitive a été de séparer les segments en **192.168.61.0/24** (BIG-IP ↔ WAF) et **192.168.60.0/24** (WAF ↔ APP).

2.3 Plan d'adressage complet

ÉQUIPEMENT	INTERFACE	ADRESSE IP / MASQUE	PASSERELLE
Kali Linux	eth0	192.168.70.10/24	192.168.70.254
Palo Alto	ethernet1/4	192.168.70.254/24	—
Palo Alto	ethernet1/3	192.168.50.254/24	—
F5 BIG-IP	self_dmz	192.168.50.10/24	192.168.50.254
F5 BIG-IP	self_dmz2	192.168.61.10/24	via route statique
WAF Linux	ens3	192.168.61.30/24	192.168.61.10

ÉQUIPEMENT	INTERFACE	ADRESSE IP / MASQUE	PASSERELLE
WAF Linux	ens4	192.168.60.20/24	—
Serveur APP	ens3	192.168.60.40/24	192.168.60.20

03 Configuration des Postes Linux

3.1 Kali Linux – Configuration réseau persistante

La configuration IP de Kali a d'abord été appliquée manuellement avec `ip addr add` et `ip route add`, mais elle disparaissait à chaque redémarrage. Une configuration persistante a ensuite été réalisée via `/etc/network/interfaces`.

Fichier `/etc/network/interfaces`

```
auto lo
iface lo inet loopback

auto eth0
iface eth0 inet static
    address 192.168.70.10
    netmask 255.255.255.0
    gateway 192.168.70.254
```

⚠ Problème – Service networking en échec

Le service échouait car l'adresse était déjà configurée manuellement, créant un conflit.

✓ SOLUTION APPLIQUÉE

```
sudo ip addr flush dev eth0
sudo systemctl restart networking
```

✓ COMMANDES DE VÉRIFICATION – KALI LINUX

COMMANDE	CE QU'ELLE CONFIRME
<code>ip a</code>	Présence de l'adresse <code>192.168.70.10/24</code>
<code>ip r</code>	Route par défaut vers <code>192.168.70.254</code>
<code>ping 192.168.70.254</code>	Connectivité locale avec le Palo Alto (zone trust)

COMMANDE

CE QU'ELLE CONFIRME

ping 192.168.50.254

Traversée correcte du firewall jusqu'au réseau DMZ

ping 192.168.60.40

Accessibilité du serveur APP à travers toute la chaîne

3.2 Serveur Application

Le serveur applicatif héberge OWASP Juice Shop sur l'interface `ens3 = 192.168.60.40/24` avec la passerelle pointant vers le WAF (`192.168.60.20`).

✓ COMMANDES DE VÉRIFICATION - SERVEUR APP

COMMANDE

CE QU'ELLE CONFIRME

ip a

Adresse 192.168.60.40/24 bien assignée

ip r

Route par défaut via le WAF 192.168.60.20

ping 192.168.60.20

Communication APP → WAF

ping 192.168.61.30

Routage APP → WAF ens3

ping 192.168.50.10

Atteinte du BIG-IP à travers le WAF

04 Configuration des Switches

i **Périmètre documenté**

Des nœuds de type switch ont été utilisés dans EVE-NG pour interconnecter les segments et équipements. Ils ont joué un rôle de couche de liaison dans la topologie. Aucune configuration CLI détaillée (VLANs, trunks, STP) n'a été réalisée dans les échanges techniques.

4.1 Rôle dans l'architecture

Les switches EVE-NG ont permis d'organiser l'architecture de base et d'interconnecter les différents segments réseau. Ils ont servi de points de raccordement entre les équipements sans nécessiter de configuration VLAN avancée dans ce contexte.

4.2 Commandes de vérification (référence)

✓ COMMANDES DE VÉRIFICATION - SWITCH CISCO IOS

COMMANDE	CE QU'ELLE VÉRIFIE
<code>show vlan brief</code>	Liste et état des VLANs configurés
<code>show interfaces trunk</code>	Ports trunk actifs et VLANs autorisés
<code>show spanning-tree</code>	Statut STP et désignation des ports
<code>show ip interface brief</code>	Adressage et état des interfaces de gestion

05 Configuration du Pare-feu Palo Alto

5.1 Interfaces et Zones

INTERFACE	ADRESSE IP	ZONE DE SÉCURITÉ
ethernet1/4	192.168.70.254/24	trust
ethernet1/3	192.168.50.254/24	dmz

✓ COMMANDES DE VÉRIFICATION - INTERFACES & ZONES

COMMANDE	CE QU'ELLE CONFIRME
<code>show interface all</code>	IP, statut et appartenance de toutes les interfaces
<code>show zone</code>	Associations interfaces ↔ zones de sécurité
<code>show interface ethernet1/4</code>	Lien, IP et état de l'interface trust
<code>show interface ethernet1/3</code>	Lien, IP et état de l'interface dmz

5.2 Problème – Ping depuis Kali vers Palo Alto

⚠ Kali ne pouvait pas pinguer l'interface trust du Palo Alto

La cause n'était pas un problème de routage mais l'absence d'un **Management Profile** autorisant le ping sur l'interface.

✓ SOLUTION APPLIQUÉE

Activation d'un profil autorisant ICMP (ping) sur ethernet1/4. Après application, Kali a pu pinguer 192.168.70.254.

5.3 Table de routage Palo Alto

RÉSEAU DESTINATION	TYPE	VIA (NEXT-HOP)
192.168.50.0/24	Connecté directement	ethernet1/3
192.168.70.0/24	Connecté directement	ethernet1/4
192.168.60.0/24	Route statique	192.168.50.10 (BIG-IP)

✓ VÉRIFICATION - TABLE DE ROUTAGE

```
show routing route
```

5.4 Règles de sécurité

NOM DE LA RÈGLE	SENS DU TRAFIC	RÔLE
allow-kali-dmz	trust → dmz	Autoriser Kali vers la DMZ
allow-ping	all → all	Autoriser ICMP pour diagnostic
allow-trust-dmz	trust → dmz	Trafic général trust vers DMZ
dmz-to-trust	dmz → trust	Chemin retour (règle ajoutée)
interzone-default	—	Règle de refus par défaut inter-zones
intra-trust	trust → trust	Trafic interne zone trust

✓ Règle déterminante ajoutée

L'ajout de la règle **DMZ → TRUST** a débloqué le chemin retour et permis une connectivité complète APP → Kali.

✓ COMMANDES DE VÉRIFICATION - RÈGLES & SESSIONS

COMMANDE	CE QU'ELLE CONFIRME
show running security-policy	Règles actives et leur logique

COMMANDE	CE QU'ELLE CONFIRME
<code>show rulebase security rules</code>	Contenu détaillé de chaque règle
<code>show session all filter source 192.168.70.10</code>	Sessions initiées depuis Kali
<code>show session all filter destination 192.168.70.10</code>	Sessions en retour vers Kali
<code>test security-policy-match</code>	Vérification d'une décision de policy

06 Configuration du WAF Linux (Nginx + ModSecurity)

6.1 Rôle du WAF

Le WAF Linux est l'équipement central de filtrage applicatif. Il assure trois fonctions principales : **recevoir le trafic** venant du BIG-IP, **agir comme reverse proxy** vers l'application, et **observer / filtrer** les requêtes HTTP malveillantes.

6.2 Adressage final

INTERFACE	ADRESSE IP	RÔLE	PASSERELLE
ens3	192.168.61.30/24	Vers BIG-IP	192.168.61.10
ens4	192.168.60.20/24	Vers APP	—

6.3 Problèmes rencontrés & solutions

⚠ Problème 1 - Double route par défaut persistante après reboot

Après modification manuelle, les anciennes routes revenaient au redémarrage. Cause identifiée : présence du fichier `/etc/netplan/50-cloud-init.yaml` qui réinjectait une ancienne configuration.

✓ SOLUTION DÉFINITIVE

```
sudo rm /etc/netplan/50-cloud-init.yaml
```

6.4 Configuration Netplan finale

```
network:
  version: 2
  renderer: networkd

ethernets:
  ens3:
```

```
dhcp4: no
addresses:
  - 192.168.61.30/24
routes:
  - to: default
    via: 192.168.61.10

ens4:
  dhcp4: no
  addresses:
    - 192.168.60.20/24
```

✓ COMMANDES DE VÉRIFICATION - WAF RÉSEAU

COMMANDE	CE QU'ELLE CONFIRME
<code>ip a</code>	Une seule IP correcte par interface
<code>ip r</code>	Une seule route par défaut via BIG-IP
<code>ping 192.168.61.10</code>	Connectivité WAF ↔ BIG-IP
<code>ping 192.168.60.40</code>	Connectivité WAF ↔ Serveur APP
<code>sysctl net.ipv4.ip_forward</code>	Capacité de routage du WAF activée
<code>tcpdump -i any icmp</code>	Visualisation du chemin réel des paquets

6.5 Configuration Nginx – Reverse Proxy

Nginx a été configuré pour relayer les requêtes vers OWASP Juice Shop sur le serveur applicatif.

```
server {
    listen 80;
    server_name _;

    location / {
        proxy_pass http://192.168.60.40:3000;
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
```

```
}  
  
}
```



Problème initial

Nginx affichait la page "Welcome to nginx" au lieu de proxifier vers Juice Shop. Cela signifiait que le site par défaut était encore actif.

6.6 ModSecurity – Installation & Activation

La présence de ModSecurity a été confirmée par les fichiers suivants :

```
/etc/nginx/modules-enabled/50-mod-http-modsecurity.conf  
/usr/lib/nginx/modules/ngx_http_modsecurity_module.so  
/etc/modsecurity/
```

Activation dans nginx.conf

```
modsecurity on;  
modsecurity_rules_file /etc/modsecurity/modsecurity.conf;
```



Erreur rencontrée – Mauvaise syntaxe ModSecurity

Erreur : *"invalid number of arguments in modsecurity_rules_file"* — causée par une syntaxe incorrecte dans la configuration nginx.

✓ COMMANDES DE VÉRIFICATION - NGINX & MODSECURITY

COMMANDE	CE QU'ELLE CONFIRME
<code>sudo nginx -t</code>	Validité syntaxique de la configuration
<code>sudo systemctl restart nginx</code>	Redémarrage correct du service
<code>nginx -V</code>	Présence du module ModSecurity compilé
<code>sudo tail -f /var/log/nginx/access.log</code>	Visibilité des requêtes HTTP en temps réel

COMMANDE

CE QU'ELLE CONFIRME

```
sudo tail -f /var/log/nginx/error.log
```

Erreurs nginx / ModSecurity

6.7 Tests d'attaque observés

TYPE

D'ATTAQUE

PAYLOAD TESTÉ

RÉSULTAT OBSERVÉ

XSS

```
<script>alert(1)
</script>
```

Pas de popup visible – requête observée dans les logs

SQL Injection

```
' OR 1=1 --
```

Test fonctionnel sur l'application Juice Shop

07 Configuration du F5 BIG-IP

7.1 Rôle du BIG-IP

Le BIG-IP a été utilisé comme **équipement de transit réseau** entre le Palo Alto et le WAF. Son rôle principal dans ce projet : porter deux Self IPs sur des réseaux distincts, gérer des routes statiques et assurer le forwarding IP via un virtual server dédié.

i Point clé – Le BIG-IP n'est pas un routeur classique

Même avec des routes statiques correctement configurées, le trafic ne transitait pas. La raison : BIG-IP nécessite un **Virtual Server de type ip-forward** pour permettre le forwarding entre réseaux.

7.2 VLANs et Self IPs

SELF IP	ADRESSE	VLAN ASSOCIÉ	RÔLE
self_dmz	192.168.50.10/24	DMZ	Vers Palo Alto
self_dmz2	192.168.61.10/24	DMZ2	Vers WAF

Recréation du Self IP (après changement de subnet)

```
tmsh delete net self self_dmz2
tmsh create net self self_dmz2 address 192.168.61.10/24 vlan DMZ2 allow-service default
tmsh save sys config
```

7.3 Routes statiques configurées

```
# Route vers le réseau applicatif (via WAF)
tmsh create net route waf_net network 192.168.60.0/24 gw 192.168.61.30

# Route vers le réseau Kali (via Palo Alto)
tmsh create net route kali_net network 192.168.70.0/24 gw 192.168.50.254

tmsh save sys config
```

7.4 Virtual Server de forwarding (ip-forward)

```
tmsh create ltm virtual forward_all \  
  ip-forward \  
  destination 0.0.0.0:any \  
  vlans-enabled \  
  vlans add { DMZ DMZ2 }  
  
tmsh save sys config
```

✓ **Résultat**

Ce virtual server a permis le forwarding complet entre les réseaux reliés au BIG-IP, débloquant toute la chaîne de connectivité.

✓ **COMMANDES DE VÉRIFICATION - F5 BIG-IP**

COMMANDE	CE QU'ELLE CONFIRME
tmsh list net self	Présence et adressage des Self IPs
tmsh list net route	Routes statiques configurées
tmsh list ltm virtual	Présence du virtual server ip-forward
route -n	Table de routage système
ping 192.168.61.30	Connectivité BIG-IP ↔ WAF
ping 192.168.60.40	Atteinte du serveur applicatif
tcpdump -i 0.0 icmp	Observation du trafic ICMP en transit

08 Applications & Services Déployés

8.1 Application initiale – DVWA

L'application DVWA (Damn Vulnerable Web App) a d'abord été tentée mais a posé des problèmes : affichage du code PHP brut, incompatibilités PHP/Apache. Elle a été abandonnée au profit d'une solution plus simple.

8.2 Application retenue – OWASP Juice Shop

- ✓ **Juice Shop sélectionné**
Application web vulnérable très utilisée en labs de sécurité, riche en vulnérabilités variées, déployée facilement avec Node.js sans dépendances complexes.

8.3 Accès à l'application

ACCÈS	URL	DESCRIPTION
Direct (sans WAF)	http://192.168.60.40:3000	Accès direct au serveur applicatif
Via WAF (reverse proxy)	http://192.168.61.30	Accès filtré à travers Nginx

✓ **COMMANDES DE VÉRIFICATION - APPLICATION**

```
curl http://192.168.60.40:3000    # Accès direct à Juice Shop
curl http://192.168.61.30        # Accès via le WAF (reverse proxy)
```

09 Tests & Validation Globale

9.1 Matrice de connectivité validée

SOURCE	DESTINATION	STATUT FINAL
Kali	Palo Alto trust (192.168.70.254)	✓ OK
Kali	BIG-IP DMZ (192.168.50.10)	✓ OK
BIG-IP	WAF (192.168.61.30)	✓ OK
WAF	APP (192.168.60.40)	✓ OK
Kali	APP (192.168.60.40)	✓ OK
APP	Kali (192.168.70.10)	✓ OK après ajout règle DMZ→TRUST

9.2 Synthèse des problèmes & solutions

⚠ Problème 1 – Deux interfaces WAF dans le même subnet

Symptômes : host unreachable, ARP incohérent, routes contradictoires

✓ SOLUTION

Séparation en deux réseaux distincts : 192.168.61.0/24 (BIG-IP ↔ WAF) et 192.168.60.0/24 (WAF ↔ APP)

⚠ Problème 2 – Routes persistantes après reboot (cloud-init)

Cause : Fichier /etc/netplan/50-cloud-init.yaml réinjectant l'ancienne config

✓ SOLUTION

```
sudo rm /etc/netplan/50-cloud-init.yaml
```

⚠ Problème 3 – Kali ne pouvait pas pinguer Palo Alto

Cause : Management Profile de l'interface ethernet1/4 n'autorisait pas ICMP

✓ SOLUTION

Activation du ping dans le Management Profile de l'interface trust

⚠ Problème 4 – BIG-IP ne forwardait pas malgré les routes

Cause : Absence de Virtual Server ip-forward

✓ SOLUTION

```
tmsh create ltm virtual forward_all ip-forward destination 0.0.0.0:any vlans-e
```

⚠ Problème 5 – Retour APP → Kali non fonctionnel

Cause : Policy Palo Alto manquante dans le sens DMZ → TRUST

✓ SOLUTION

Ajout de la règle DMZ → TRUST autorisant le trafic retour

9.3 Tests de sécurité applicative

TYPE D'ATTAQUE	PAYLOAD	RÉSULTAT
XSS Réfléchie	<pre><script>alert(1) </script></pre>	Pas de popup – observé dans logs nginx
SQL Injection	<pre>' OR 1=1 --</pre>	Test réussi sur Juice Shop

10 Conclusion & Améliorations

10.1 Bilan technique

✓ Réalisations validées

- Conception complète de la topologie EVE-NG
- Adressage cohérent multi-segments
- Configuration Linux persistante (Kali + APP)
- Interfaces, zones et routes Palo Alto
- Règles de sécurité inter-zones
- Self IPs et routes statiques BIG-IP
- Virtual Server ip-forward BIG-IP
- Configuration réseau WAF (Netplan)
- Suppression conflit cloud-init
- Déploiement OWASP Juice Shop
- Chaîne de connectivité complète validée

→ Améliorations possibles

- Finaliser ModSecurity pleinement opérationnel
- Intégrer les règles OWASP CRS
- Journalisation WAF claire et centralisée
- Configuration load balancing par pool BIG-IP
- Supervision avancée des journaux
- Configuration VLAN dédiée sur les switches
- Profils de sécurité Palo Alto (IPS, AV)
- NAT sur le Palo Alto

10.2 Compétences mobilisées



Architecture réseau

Conception de topologies multi-segments cohérentes



Palo Alto

Zones, interfaces, politiques de sécurité, routage



F5 BIG-IP

Self IPs, routes, virtual server ip-forward



WAF / Nginx



Administration Linux



Tests de sécurité

Reverse proxy, ModSecurity,
filtrage HTTP

Netplan, routage, diagnostic
réseau

XSS, SQLi, observation des
logs applicatifs

A Annexe – Commandes de vérification

Linux (Kali / WAF / APP)

```
ip a
ip r
arp -n
ping <ip>
curl <url>
tcpdump -i any icmp
ss -tulpn
systemctl restart
networking
systemctl restart nginx
nginx -t
nginx -V
tail -f
/var/log/nginx/access.log
tail -f
/var/log/nginx/error.log
```

Palo Alto Firewall

```
show interface all
show interface
ethernet1/3
show interface
ethernet1/4
show zone
show routing route
show rulebase security
rules
show running security-
policy
show session all filter
source <ip>
show session all filter
destination <ip>
show arp
ping source <ip> host
<ip>
test security-policy-
match
```

F5 BIG-IP

```
tmsh list net self
tmsh list net route
tmsh list ltm virtual
tmsh list net vlan
route -n
ping <ip>
tcpdump -i 0.0 icmp
tmsh save sys config
```